



정산 표준화 솔루션 · 개발 상세 기록

배포본 이후 개발 상세 보고서

서비스화 · 계약 체계 · 회원/권한 · 보안 격리 (main → feat 전체)

작성일	2026년 8월 2일
작성자	최혜윤 (기획·PO 총괄)
연락처	rachel@hive-mind.kr
대상	개발본(feat 브랜치) — 배포본(main·v2) 이후 전체 작업
목적	학습·인수인계·보고 (기술 배경·의사결정 포함)
불변식	431,296행 · 완전매칭 99.50% · 원본 대사 검증 86건 (전 과정 유지)

0. 이 문서의 범위와 읽는 법

배포본(main, v2 고도화)은 "정산 데이터 분석 도구"였다. 이후 개발본(feat)에서 이를 **출판사 단위 멀티테넌트 서비스**로 전환하고, 계약 체계·회원/권한·보안 격리를 쌓았다. 이 문서는 그 전 과정을 **무엇을·왜·어떻게** 순으로 상세히 정리한다.

각 장의 **왜** 박스는 의사결정의 배경(학습 포인트)이다. 코드 블록은 핵심 로직의 형태만 발췌했다.

개발 순서(요약)

단계	핵심
서비스화 전환 (v2→v3)	분석 도구 → 멀티테넌트 서비스, 영속 마스터, 역할별 IA
출판사↔레이블 계층·매핑	레이블 위 출판사 депс, 본부장 매핑 통합, 에피루스 파서 교정
계약 체계	넘버링·상태(초안/확정)·유효기간·유통대행 지급·소급 일괄
정산 산식	작가/출판사 지급·MG 누적·명세서 산식 통일
회원·권한·온보딩	RBAC, 가입·승인·초대·동의·온보딩
보안 격리	서버측 테넌트 격리 + 엔드포인트 권한 가드
운영·품질	감사로그·비번·초대만료, 리뷰·QA·회귀

1. 서비스화 전환 (v2 → v3)

무엇을

정산 데이터 중심 화면을, **출판사(테넌트)**를 **고객 단위**로 두는 서비스 계층으로 전환. 출판사·계약·유통사 정보를 정산 데이터에서 파생하지 않고 **영속 마스터(JSON)**로 분리 관리하고, 정산은 그 위에 얹는 구조로 재설계.

어떻게

- 영속 마스터: `tenants.json` (출판사) `contracts.json` (계약) `tenant_distributors.json` (유통사). 정산 세션과 독립.
- 조회 계층은 **read-only**. 정산 매칭 엔진(engine)은 손대지 않아 회귀 불변식 유지.
- 역할별 IA: 운영자 콘솔 ↔ 출판사 워크스페이스.
- core(엔진, 순수·무상태) ↔ service(마스터·워크플로) 모듈 경계. 모노레포 라이브러리 호출, HTTP 전환 대비.

왜 — 배포본은 정산서를 올려야만 화면이 동작했다. 서비스라면 정산 데이터 없이도 고객·계약을 관리할 수 있어야 한다. 그래서 "데이터에서 파생"을 "영속 마스터"로 뒤집는 것이 전환의 핵심이었다.

2. 출판사↔레이블 계층과 매핑

무엇을

정산 데이터의 최소 단위는 **레이블**(임프린트)이고, 그 위에 **출판사** 덤스가 있다(예: 매드햇→스토린랩). 레이블을 출판사로 묶는 매핑을 구축.

어떻게

- 본부장 제공 매핑표(출판사별 레이블명) 시드 + **정규화 매칭**(_lcanon: 괄호·법인격·공백·대소문자 제거)으로 표기 변형 흡수.
- 미매핑 목록을 본부장 2차 확인 → **통합 매핑표 458 레이블 → 158 출판사**. 테넌트 843 → 128곳.
- 미상 레이블은 데이터로 역추적(같은 작품이 이미 매핑된 레이블에 있는지). 작가 교차는 노이즈라 배제.

에피루스 사례 — "미매핑 = 매칭 실패"가 아니다

미매핑 824건 중 586건이 실은 **책 제목**이었다. 유통사 에피루스 정산서에 출판사 열이 없어, 파서가 4번 열(작품 부제)을 레이블로 읽은 것. 본부장 매핑상 에피루스=블루마운틴소프트 단일 채널이므로, 파서에 **상수 레이블**을 지정해 교정.

```
dict(platform="에피루스", ... columns_pos=dict(title=2, author=3, gross=6, settle=8),
      label_const="에피루스") # 4번 열(부제) 제외, 유통사=단일 레이블 고정
```

왜 — 숫자(824)만 보면 매핑 실패로 오해한다. 실제 값을 열어보니 원본 포맷 차이로 엉뚱한 열이 레이블로 들어온 것. **수치가 아니라 데이터를 열어봐야 진짜 원인이 보인다.**

3. 계약 체계

3.1 계약 넘버링

계약마다 고유번호 부여. 번호만으로 출판사·원작·매체·권리·형태가 읽힌다.

```
0001 - AA001 - N - 1 - 00
|      |      |      |      |
|      |      |      |      |  L 콘텐츠유형(웹소설 00 / 웹툰 01 / 번역 02 ...)
|      |      |      |      |  L 계약유형(1 배타적발행권 / 2 2차적저작물 / 3 외주)
|      |      |      |      |  L 웹소설(N) / 웹툰(T)
|      |      |      |      |  L 콘텐츠 고유번호(원작 1개=하나, 파생은 공유)
|      |      |      |      |  L 출판사 구분값(첫 계약 시 자동 0001~)
```

파생 계약(웹툰화·외주)은 원작의 콘텐츠번호를 공유하고 뒤 세 자리로 구분: 0001-AA001-N-2-01 (웹툰화 2차저작물).

3.2 상태 · 유효기간 (신뢰성)

요소	정책·동작
상태(초안/확정/종료)	소급 일괄=초안. 초안은 예상 지급액 미반영 → 확정 후 반영(미검토 기본값 부풀림 방지)
유효기간(시작/종료월)	해당 기간 정산행에만 배분을 적용. 서명 이전 과거 소급 방지

3.3 소급 일괄 등록 (온보딩)

출판사 합류 시 기존 계약을 한꺼번에 등록. 이미 올라온 정산 데이터의 **작품·작가**를 계약 초안 소스로 재활용 → 미계약 작품 목록에서 선택 → 배타적발행권 초안 일괄 생성(콘텐츠번호 자동 연번). 이후 배분율·계약서를 개별 보정.

왜 — 계약은 신규가 아니라 **기존 계약을 소급** 등록하는 게 기본 시나리오. 한 건씩 입력은 비현실적이라, 가진 데이터(정산)를 초안 소스로 뒤집었다.

4. 정산 산식

작가 지급 = 유통사 **제공 정산액** × 계약 배분율 - 선인세(MG) - 원천징수. (원천 인세엔진이 아니라 제공값 기준.)

4.1 작가 지급 vs 출판사 지급 (유통대행 3계층)

"작가 - 출판사 - 관리자(하이브마인드)" 3계층. 유통대행사 관점에서 **출판사를 작가처럼** 취급(지급처=출판사). 계약 메커니즘은 그대로 두고 매칭 키만 작가명 → 출판사명(레이블→출판사 해석·산하 레이블 합산)으로 전환.

```
payee_type=="출판사": rows = 레이블이 그 출판사로 해석되는 정산행
                        base = Σ settle · payout = base × 배분율 - MG - 세
```

4.2 작품 범위 · 중복 경고

- 여러 작품 = OR(하나라도 포함). 포함매칭이라 권차·외전 자동 포함.
- 같은 지급대상 계약이 **실제 매칭 정산행 기준**으로 겹치면 이중 배분 경고(문자열 아닌 행 교집합 판정 → 오탐 없음).

4.3 MG 누적 · 명세서 통일

- MG를 로드 기간 누적에서 회수하고 **미회수분(잔액)** 표시(이월 대상).
- 작가 명세서 PDF를 **확정 계약의 배분율·MG·세율**로 통일 → 계약관리 예상지급액과 값 일치(기존 0.033 하드코딩·별도 요율 제거).

정산 **계산식**을 바꾸는 항목은 회귀 위험이 커, 4가지 정책(초안/확정·유효기간·MG 모델·명세서 산식)을 먼저 결정한 뒤 반영했다. 반영 후에도 431,296/99.50%/86 불변.

5. 회원 · 권한 · 온보딩

5.1 역할·권한(RBAC)

조직	역할	요지
운영사	최고관리자 / 운영자 / 뷰어	전 기능·승인 / 운영·계정발급 / 조회
계약사	출판사관리자 / 담당자	자사 관리·사용자 관리 / 자사 조회

권한 키(resource:action)를 역할에 매핑. 원칙(sian ERP 참고): **활성 상태만 로그인, 최고관리자 바이패스, 동의 전 차단.**

5.2 흐름

- **운영사 가입·승인**: 최초 가입자=최고관리자 자동(부트스트랩), 이후 승인 필요.
- **계약사 계정 발급**: 운영자가 이메일 초대 → 링크(/invite/token) → 이름·비번 설정 → 활성화. 첫 계정=출판사관리자.
- **최초 접속**: 동의 화면(약관) → 담당자 정보 입력(온보딩) → 워크스페이스.
- **자사 사용자 관리**: 출판사관리자가 자사 담당자만 초대·관리.

5.3 브랜드 표기

계약사 화면은 **계약사명이 주 브랜드**, 하이브마인드는 "powered by" 제공처로 표기(로그인 조직에 따라 자동 전환).

6. 보안 — 서버측 테넌트 격리

무엇을 / 왜

설계 리뷰에서 최우선 지적: 권한 검사가 회원/마스터 쓰기에만 있고, **정산 조회·내보내기·업로드·매칭은 "로그인+활성"만 확인했다.** 스코프를 클라이언트가 넘기는 값에 의존 → 계약사가 파라미터만 바꿔 타사 매출·계약·계좌·정산서 열람 가능했다. 외부 계정 배포 전 반드시 차단해야 하는 구멍.

어떻게

- 정산 조회/내보내기/명세서를 **로그인 사용자의 테넌트 레이블로 서버측 강제**(클라이언트 스코프 무시, 라벨 교집합).
- 계약·유통사·첨부는 **소속 테넌트 검사**(타사 403). 첨부 다운로드 IDOR 차단.
- 전역 매칭/연구소 변경 POST는 운영자(lab:manage) 전용 미들웨어 가드.

실측 결과

검증	결과
같은 세션 · 계약사 summary	자사 6.04억만
같은 세션 · 운영자 summary	전체 11.97억
계약사 → 타사 계약/유통사/첨부	403
계약사 → 라벨 인젝션(타사 강제)	0건(교집합 차단)

왜 — "화면에서 안 보이면 안전"이 아니다. 클라이언트는 조작 가능하므로 **권한·스코프는 반드시 서버에서** 강제해야 한다. RBAC 모델이 있어도 엔드포인트에 연결되지 않으면 무의미하다.

7. 운영 · 품질

7.1 운영 안전장치

- 초대 만료(14일)·비밀번호 8자·상태값 검증·**마지막 최고관리자 정지 방지**(자기잠금 차단).
- 비밀번호 재설정(본인 변경 + 관리자 임시 초기화), 초대 취소/재발송.
- **감사 로그**: 로그인(성공/실패)·가입·승인·권한·상태·초대·비번 이벤트 기록·조회.
- 세션 시크릿 파일 영속(재시작해도 로그인 유지), 401 시 로그인 자동 이동.

7.2 품질 · 검증

- 모든 정산 영향 변경 후 **회귀 불변식 재확인**(431,296/99.50%/86) — 전 과정 유지.
- 설계 리뷰 2건(회원·권한 / 정산·계약)으로 갭·정책·보안 도출. 비이슈 2건도 반증(과도한 수정 방지).
- 전체 기능 QA 테스트 시트(8시트 90케이스)·단계별 테스트 시나리오 작성.

8. 성과 요약 · 남은 과제

지표	배포본(v2)	개발본(feet)
성격	정산 분석 도구	멀티테넌트 서비스
출판사·계약·유통사	정산 데이터 파생	영속 마스터(분리)
진입	정산 업로드 후	업로드 없이 관리
사용자	단일 접근	회원·역할·권한(RBAC)
데이터 격리	없음	서버측 테넌트 격리
계약	요율 직접	넘버링·상태·유효기간·유통대행·명세서 통일
테넌트 수	레이블 혼재	128 출판사(매핑 정리)
회귀 불변식	431,296/99.50%/86	동일(유지)

남은 과제

- 초대 **실제 이메일 발송**(SMTP 자격증명 필요, 현재 링크 대체).
- 교차-업로드 **MG 영구 원장**("정산 마감/확정 실행" 기능과 함께).
- 플랫폼 MG·정산을 조정(본부장 Q1~Q3 확인 후), 소소 편의(배분율 일괄 수정 등).

이 개발본은 로그인·권한·온보딩·데이터 격리·계약 신뢰성·회원 운영을 갖춘 상태로, 외부 계약사 계정 배포가 가능한 최소 안전 선을 통과했다.